

IN2120 Informasjonssikkerhet

Høst 2025

Del 13: Informasjon for eksamen



Audun Jøsang
Universitetet i Oslo

Del 1: Generelle begreper for informasjonssikkerhet

- Forstå hva informasjonssikkerhet er
 - Kjenne ulike betydninger av begrepet sikkerhet, og presis oversettelse av engelske begreper
 - Definisjon av informasjonssikkerhet (ISO/IEC 27000) som beskyttelse av KIT
 - Forstå hvordan ulike typer angrep kan skade KIT
- Betydning av, og forskjell mellom sikkerhetskonsepter
 - Forskjell mellom symmetrisk og asymmetrisk krypto
 - Forskjell i dataautentisering med MAC (Message Authentication Code) og digital signatur
 - Forskjell mellom tilgangsbefugning og tilgangskontroll
- Betydning av og sammenheng mellom viktige begreper:
 - Trusselaktør og trussel(scenario), angrep (at en trussel blir utført), hendelse, sårbarhet, verdi/ressurs, konsekvens, risiko og risikonivå

Del 2: Kryptografi

- Hash-funksjoner
 - Krav til hashfunksjoner.
 - Kjenne de mest kjente hash-funksjonene, og om de regnes som sikre
- Symmetriske krypteringer
 - Krypteringsmoduser for block-chiffer: ECB, CTR (Tellermodus) og CBC
- Asymmetriske algoritmer
 - Vite hvilke nøkler (offentlig/privat og Alice/Bob) som brukes i asymmetrisk kryptering og DigSig
 - Forstå hybrid kryptering og hvorfor det ikke gir fremoverhemmelighold
- Diffie-Hellmann (DH) nøkkelutveksling
 - Forstå hvorfor den utvekslede øktnøkkelen er anonym, dvs. uten autentisering
 - Forstå hvordan DH kombinert med DigSig gir øktnøkler som gir fremoverhemmelighold
- Postkvantekrypto
 - Forstå hvorfor det er nødvendig
 - Vite at standardiserte postkvante-algoritmer snart blir standardisert

Del 3: Nøkkelhåndtering og PKI

- PKI
 - Hva er hensikten
 - Krav til beskyttelse (konfidensialitet eller autentisitet/integritet) av ulike typer nøkler (hemmelig, privat/offentlig) for nøkkeldistribusjon
- Sertifikater (for offentlige nøkler)
 - Navn på standard for sertifikater
 - Hvordan sertifikater er lenket sammen fra rot til subjekt/server-sertifikat.
 - Forstå hvilken type tillit som sertifikater gir: un tillit til identitet, og ikke til f.eks. lovlighet/seriøsitet/kvalitet av nettsteder eller programvare

Del 4: Trusselaktører, angrepsvektorer og skadevare

- Kjenne vanlige kategorier av trusselaktører og angrepsvektorer
 - Phishing (ulike varianter)
 - Drive-by-angrep,
 - SQL-injeksjon
 - Passordkracking
 - Privilege escalation
 - Leveransekjedeangrep
- Kjenne prinsipper for vanlige former for skadevare
 - virus, trojaner, dataorm, exploit, rootkit, makrovirus, skadelig javaskript, bakdør, bott-program, spionprogram, løsepengevirus, keylogger

Del 5: Pentesting og angrepsmetodikk

- Forskjell mellom hacking og etisk hacking (pentesting)
 - Kjenne strafferammen for datainnbrudd med hacking
 - Krav til å kunne gjennomføre (lovlig) pentesting / etisk hacking
- Forskjellige typer pentesting
 - svartboks, hvitboks, gråboks
- Trinn i pentesting
- Teknikker
- OSINT, phishing, kartlegging, prøve tilganger og tjenester,
 - prøv Sudo, få root-tilgang, passordcracking, booting
 - sjekk om programmer har kjente sårbarheter

Del 6a: Systemsikkerhet

- Sikkerhet i mikroprosessorer og OS
 - OS privilegienivåer
 - kompromittering av minne med buffer overflow,
 - beskyttelse av minne med ASLR, No-Execute
- Virtualisering
 - Hypervisor, gjeste-OS, verts-OS
 - Type 1 og type 2 virtualiseringsarkitektur
 - Kontainerarkitektur
- Forstå prinsippet for sikker oppstart med UEFI

Del 6b: Fysisk sikkerhet

- Prinsipper for sikkert arbeid
- Fysisk skjerming av verdier og områder
- Kameraovervåkning
- Automatisert video-overvåkning
- CPTED

Del 7a: IS-ledelse

- 27001 og PDCA
 - Hva er sammenhengen
- NSMs grunnprinsipper for IKT-sikkerhet
 - Hva det er, og hva det kan brukes til
- NIST Cyber Security Framework
 - Hva det er, og hva det kan brukes til

Del 7b: Risikostyring

- Risikostyringsprosess fra ISO/IEC 27005
 - Kjenne overordnet struktur for risikostyring og beslutningspunkter
 - Kjenne hovedtrinnene i risikovurdering
- Trusselmodellering tilnærminger:
 - Angripersentrisk
 - Arkitektursentrisk
 - Verdisentrisk
- Risikoanalyse, typer
 - Vite forskjellen på kvalitativ og kvantitativ
 - Det blir ingen case-oppgave om risiko.

Del 8: Brukerautentisering

- Ulike former for brukerautentisering
- Passordsikkerhet (noe du vet)
 - hashing, salting, passordkompleksitet
- Enheter(noe du har)
 - OTP-brikker, online-enheter, adgangs- og ID-kort, sekundærkanaler
 - Phishingresistent autentisering med passnøkler
- Biometriske systemer (noe du er)
 - Feilrater og kvalitetsvurdering
- Rammeverk for autentisering i e-forvaltning
 - Autentiseringsnivåer
 - Kjenne hvilke autentiseringsnivåer som støttes av norske eID-ordninger

Del 9: Identitets- og tilgangshåndtering

- Betydning av entitet / identitet / attributt / digital identitet
- ID-modeller
 - Silomodell / føderert modell
- Sentraliserte / distribuerte føderasjonsmodeller
 - 4 ulike kategorier
 - Forstå hvorfor en IdP (eID-leverandør) tilhøre en spesifikk kategori
 - Kjenne norske eID-leverandører
 - Krav for europeisk eID
- Kjenne prinsippet og scenario for OpenID Connect
- Tilgangskontroll
 - Prinsipper/modeller for MAC, DAC, RBAC og ABAC
 - Kjenne prinsipp og scenario for OAuth

Del 10: Nettverkssikkerhet

- Strukturen av internet-stakken
 - Vite på hvilket lag de ulike protokoller hører hjemme.
- Prinsipp for IP-adresser, eksterne og interne
- Grunnleggende nettverkssikkerhet: typer brannmurer og IDS
- Kjenne navn og standardporter for kjente applikasjonslagprotokoller
- TLS (Transport Layer Security)
 - Hvordan TLS 1.3 støtter fremoverhemmelighold.
- IPSec (Internet Protocol Security)

Del 11: Cyberkrigføring

- Tre typer cyberoperasjoner:
 - Offensiv, defensiv, og spionasje
 - Hva er nyttig
 - USA har doktrine for offensiv cyberops
- Cyberavskrekking og cyberkaperfart
 - Hva er det
- Hvordan er sektorvise responsmiljøer organisert?

Del 12: Innebygd informasjonssikkerhet

- Hva er SDL (trenger ikke huske alle 7 faser)
- STRIDE
 - Hva betyr hver bokstav
- OWASP og OWASP Top 10
 - Hva er det
- CVE, NVD og CVSS
- DevSecOps og SHIFT LEFT

Eksamen i Silurveien

- 16. desember 2025, kl.15:00-19:00.
- Praktisk info rundt digital eksamen i Silurveien 2:
<https://www.uio.no/studier/eksamen/inspera/index.html>
- Digital eksamen består av ulike oppgavetyper.
- Oppgaver fra alle forelesningstemaer, der oppgavene fokuserer på innhold i presentasjoner, oblig-oppgaver, teorioppgaver og læreboka.
- Ikke pensum:
 - Kapittel 7: Trådløs sikkerhet.
 - Kapittel 10: Personvern
 - Kapittel 15: KI og cybersikkerhet
 - Gjesteforelesninger (Simen Bakke (del 11a) og Synne Stokkevåg Berg, del 12a))
- 4 timer arbeidstid
- Lykke til !

Første side på eksamenen

Informasjon om eksamenen



UiO : Institutt for informatikk Det matematisk-naturvitenskapelige fakultet

Avsluttende eksamen i IN2120 Informasjonssikkerhet (Høst 2025).

Dato og tidspunkt: 16.desember 2025, kl.15:00 - 19:00 (4 timer).

Ingen hjelpemidler er tillatt.

Merk følgende:

- Oppgavene i denne eksamenen er gruppert i åtte deler. Den første delen dekker grunnleggende aspekter ved informasjonssikkerhet på tvers av pensum, mens de øvrige delene er fra utvalgte områder av pensum.
- Det er mulig å oppnå totalt 100 poeng (= 100%) ved å besvare alle oppgavene korrekt.
- Man kan navigere frem og tilbake mellom oppgavene.
- Skåring for hver oppgave angis eksplisitt. Det kan gis negative poeng for feil svar/valg, men total poengsum for hele oppgaven er minimum 0 (selv om summen over alle svarene er negativ).
- Vær kortfattet når du skriver tekst som svar på en tekstoppgave. Svaret kan skrives på norsk, svensk, dansk eller engelsk.
- Les oppgaveteksten nøye og spesielt der du skal fylle inn verdier i en tekstboks.
- I navigasjonslinjen nederst på skjermen indikeres fullførte oppgaver med blå søyler.

Tips! Siden du kan gå frem og tilbake kan det være lurt og først svare på oppgavene du syns er lette, og deretter gå tilbake til vanskelige oppgaver hvis du har tid.

Lykke til, hilsen Audun, Åvald og Nils!